⚖️ 參考 8436 大江生醫合規標竿 ｜ 📜 金管會生成式 AI 指引 & 證交所資通管控標準

信源全球 (RSI Group) *企業級生成式 AI 治理架構藍圖*

全面引進 8436 大江生醫備受資本市場肯定之 AI 治理體系，結合**金管會生成式 AI 核心六大指引**、**證券交易所上市上櫃資通安全管控指引**與**內部控制準則第 9 條之 1**。針對成衣跨國製造建立**「品牌客戶智財無菌室 (IP Clean Room)」**、**「訂單款式結構圖去識別化」**、**「人機協同 (Human-in-the-Loop) 4-Gate 產前門禁聯鎖」**與**「全生命週期決策審計追蹤」**，確保 AI 創新與企業機密治理雙軌兼備。

專案指導：**周文津 副總經理 (計劃主持人)** ｜ 架構規劃：**Howard Liao Ph.D. 外部顧問 (執行負責人)**

FORM SUITE: RSI-SIMULTANEOUS-ROLES-2027

一、信源全球 AI 治理六大核心支柱 (The 6 Pillars of AI Governance)

全面落實金管會 GenAI 六大原則，杜絕演算法黑箱、資料外洩與 AI 幻覺引發的生產事故

🏛️ 支柱一：治理組織與權責問責機制

金管會原則一

明定 AI 決策主體為企業本身，絕不將責任推託給演算法。

- 成立跨部門「AI 治理與風險審查委員會」，由周副總親自主持。
- 明定各項 AI 應用（如 Tech Pack 翻譯、以圖找圖、生管排產）之業務權責主管。
- 建立 AI 事故分級與緊急阻斷機制，發生異常時可在 30 秒內降級回人工程序。

🛡️ 支柱二：品牌智財無菌室 & 去識別化

金管會原則二

參考 8436 大江生醫專利配方隔離架構，建立國際成衣大品牌（Nike / Lululemon）智財無菌室：

- **去識別化預處理**：款式結構圖上傳前自動去除品牌 Logo、款號與工廠代碼。
- **Zero Data Retention (ZDR)**：要求 AWS 與外部模型供應商簽署不留存、不用於重訓協定。
- **ABAC 租戶實體隔離**：不同品牌客戶之版型資產與做工知識庫實施強制隔離。

⚖️ 支柱三：製程算法公平性與防偏見機制

金管會原則三

成衣生產排線與車縫計件直接牽涉基層技工薪資與工廠考核，演算法必須客觀公正：

- 車縫線平衡率 (Line Balancing) 演算法必須基於標準工時 (SAM) 與技能矩陣客觀派工。
- 定期審查 AI 模型輸出結果，嚴禁出現特定工段、班組或國籍勞工的系統性歧視。
- 保留勞工計件工資人工覆核爭議申訴通道，維護跨國勞工人權合規。

🔍 支柱四：透明度與可解釋性 (Explainable AI)

金管會原則四

拒絕黑箱決策，AI 產出之每一項成衣技術建議都必須具備引用依據：

- **RAG 引用溯源**：Tech Pack 翻譯與工藝提醒，必須標註來源客審文件之頁碼與章節。
- **以圖找圖相似度量化**：輸出相似歷史訂單時，明確標註相似度百分比與比對依據。
- **IE 瓶頸工序解釋**：排產模擬預測產能時，需同步標出瓶頸工位之等待 SAM 損失。

🤝 支柱五：人機協同 (Human-in-the-Loop · HITL)

金管會原則五

堅決落實人機協同，嚴禁 AI 自動下達未經人工覆核之成衣投產或採購指令：

- **4-Gate 產前門禁聯鎖**：AI 提供物料齊套預測，但 Gate 1~4 放行必須由生管主管電子簽字。
- **報價覆核機制**：AI 輔助計算之大貨布損與成衣報價，業務副總/總監簽核前不得發出。
- **Tech Pack 翻譯雙簽**：技術部資深版師必須對關鍵特殊部位做工翻譯進行人工確認。

🔐 支柱六：系統強韌度、護欄防禦與稽核日誌

金管會原則六

防禦 Prompt 注入攻擊 (Prompt Injection)，保障 AI 中台高可用性：

- **輸入/輸出雙向護欄**：配置 Llama-Guard 3 與 DLP 模組，過濾敏感報價與異常提問。
- **決策審計日誌 (Audit Trail)**：完整留存每次呼叫之時間戳、操作人、Prompt 與輸出，留存 3 年。
- **海外廠斷網韌性**：海外三廠具備 48~72hr 離線生產自律，海纜斷網時 AI 服務自動優雅降級。

二、公開發行內控準則第 9 條之一 & 上市上櫃資通安全管控對齊

將生成式 AI 與 API 平台納入集團年度內部控制查核計畫，杜絕法規與治理漏洞

法規與準則項目	大江生醫 (8436.TW) 標竿做法	信源全球 (RSI Group) 落地實施機制
公開發行公司內控第 9 條之 1	將大型語言模型、API 閘道與生物資料庫列為年度內部稽核重點，每季出具稽	• 將「Tech Pack 翻譯知識庫」、「以圖找圖模型」與「API 閘道」納入年度內

法規與準則項目	大江生醫 (8436.TW) 標竿做法	信源全球 (RSI Group) 落地實施機制
(資通安全查核)	核報告。	控查核。 • 每季清查模型存取帳號權限，離職同仁當日即時封鎖停權。
證交所資通安全管控指引 (特權存取與金鑰)	使用 HashiCorp Vault 實施核心資料庫動態金鑰自動輪替，杜絕明文金鑰外洩。	• AWS API 金鑰與 MS SQL 連線字串全數封裝於安全金鑰庫，禁止寫死在代碼中。 • 核心管理員強制推行 Authenticator App MFA 雙因子認證。
智慧財產權與專利保護 (IP Protection)	專利配方與發酵菌種機密在專屬安全沙盒中運算，嚴禁進入公共模型訓練池。	• 客人「訂單款式結構圖」與版型檔案經去識別化後始調用 AWS 進行向量比對。 • 外部協力廠商使用 Clientless Portal 隔離存取，禁止下載原始版型檔案。
AI 運算成本治理 (FinOps Token Quota)	以 HowardRoute 實施部門 Token 消耗配額監控，動態任務分流節省成本。	• 建立生管、業務、開發各部門月度 Token 消耗限額，防止算力與費用失控。 • 採「地端私有模型 + 雲端商業大模型」混合架構，兼顧成本與效能。